

would directly launch the attack.

So we construct the following URL:

http://localhost/WebGoat/attack?Screen=191&menu=900&field1=<script>alert("Gotcha!");</script>

This pre-injects the script into the page, and any user who follows this link will automatically run the script specified in the URL.

Note: The URL given above is for an instance of WebGoat running on the local computer. After downloading, installing and launching WebGoat, you will be able to test it as well.

The third DOM-based XSS Attacks rely on a web page's use of the document.url or document.location properties. For example, a web page that is displaying all entries for a tag might have a URL such as:

http://www.somesite.com/search.php?tag=android

This webpage might be retrieving the url, and extracting the tag name from the parameters list in order to display it on the page. So we could use a URL such as:

http://www.somesite.com/search.php?tag=<script>alert("Gotcha!")</script>

Then the webpage just needs to process the URL, and the DOM will do the rest.

* Whoops! You entered injected html instead of your three digit code. Please try again.

Shopping Cart			
Shopping Cart Items -- To Buy Now	Price	Quantity	Total
Studio RTA - Laptop/Reading Cart with Tiling Surface - Cherry	\$69.99	1	\$69.99
Dynex - Traditional Notebook Case	\$27.99	1	\$27.99
Hewlett-Packard - Pavilion Notebook with Intel Centrino	\$199.99	1	\$199.99
3 - Year Performance Service Plan \$1000 and Over	\$299.99	1	\$299.99

The total charged to your credit card: \$1997.96

Enter your credit card number:

Enter your three digit access code:

3.2.4 Broken authentication and session management

“Application functions related to authentication and session management are often not implemented correctly, allowing attackers to compromise passwords, keys, session tokens, or exploit other implementation flaws to assume other users’ identities.”

Such vulnerabilities exist because web site creators are not careful enough about the security of their authentication and session management. Websites need to be built keeping in mind that user’s may not always be as careful with the security of their accounts.

Users don’t always log out of their accounts when they are done, and they are often not careful about the data they might be exposing by sharing